

FRAMEWORK CARD

FRAMEWORK-NIST-01

IDENTIFY FUNCTION

FRAMEWORK: NIST CSF

FUNCTION: Identify (AM - Asset Management, RM - Risk Management)

FOCUS: Knowing what systems/data you have and what risks they face

ASSESSMENT CRITERIA

Asset inventory (what systems exist?); Data classification (what data is sensitive?); Risk assessment (what could go wrong?); Threat intelligence (what are realistic threats?);

SCORING (1-5 STARS)

(1): No asset inventory, no risk assessment; (2): Partial inventory, informal risk assessment; (3): Complete inventory, documented risk assessment; (4): Inventory regularly updated, risk assessment reviewed annually; (5): Real-time asset visibility, continuous risk assessment;

TYPICAL FINDINGS

Unknown systems (shadow IT); Unclassified data (don't know what's sensitive); Missing risk assessment; Risk assessment not updated;

REMEDIATION

Discovery tools (find all systems); Data classification policy; Annual risk assessment; Asset management system;

INCIDENT ZERO · AUDIT & COMPLIANCE

FRAMEWORK CARD

FRAMEWORK-NIST-02

PROTECT FUNCTION

FRAMEWORK: NIST CSF

FUNCTION: Protect (PR.AC - Identity Management & Access Control, PR.AT - Awareness & Training, PR.DS - Data Security, PR.IP - Information Protection Processes, PR.MA - Maintenance, PR.PT - Protective Technology)

FOCUS: Building security controls to prevent/slow attacks

ASSESSMENT CRITERIA

Access controls (only authorized users); Employee training (security awareness); Data protection (encryption, classification); Information protection (DLP, data loss prevention); Business continuity (backup, disaster recovery);

SCORING (1-5 STARS)

(1): No controls; (2): Basic controls (passwords); (3): Good controls (MFA, encryption); (4): Strong controls (defense-in-depth); (5): Excellent controls (comprehensive, tested);

TYPICAL FINDINGS

Weak authentication (no MFA); Poor training (phishing success rate >10%); Unencrypted data; No backup strategy; Defense gaps;

REMEDIATION

MFA deployment; Security training program; Encryption implementation; Backup/DR strategy; Penetration testing;

INCIDENT ZERO · AUDIT & COMPLIANCE

FRAMEWORK CARD

FRAMEWORK-NIST-03

DETECT FUNCTION

FRAMEWORK: NIST CSF

FUNCTION: Detect (AE - Anomalies & Events, CM - Continuous Monitoring)

FOCUS: Detecting attacks as they happen

ASSESSMENT CRITERIA

Log monitoring (are suspicious activities logged?); Anomaly detection (is suspicious behavior caught?); Continuous monitoring (24/7 surveillance); Alert procedures (who responds to alerts?); Threat intelligence integration (using threat data);

SCORING (1-5 STARS)

(1): No logging, no monitoring; (2): Logging exists, limited monitoring; (3): SIEM deployed, some alerts; (4): SIEM with good rules, 24/7 monitoring; (5): Mature SOC, threat intelligence integrated;

TYPICAL FINDINGS

No SIEM deployed; Alerts not reviewed; No 24/7 monitoring; Response time too slow; Threat intel not integrated;

REMEDIATION

SIEM deployment; Alert rule tuning; SOC staffing (24/7 coverage); Response procedures; Threat intel integration;

INCIDENT ZERO · AUDIT & COMPLIANCE

FRAMEWORK CARD

FRAMEWORK-NIST-04

RESPOND FUNCTION

FRAMEWORK: NIST CSF

FUNCTION: Respond (RS.RP - Response Planning, RS.CO - Communications, RS.AN - Analysis, RS.MI - Mitigation, RS.IM - Improvements)

FOCUS: Responding to breaches/attacks

ASSESSMENT CRITERIA

Incident response plan (documented procedures); Response team (trained, staffed); Communication plan (who gets told when); Investigation procedures (forensics); Post-incident review (lessons learned);

SCORING (1-5 STARS)

(1): No incident response plan; (2): Plan exists, not tested; (3): Plan exists, annual testing; (4): Plan regularly tested, team trained; (5): Mature response, regular exercises, continuous improvement;

TYPICAL FINDINGS

No incident response plan; Response team not trained; No communication plan; Investigation procedures unclear; No post-incident reviews;

REMEDIATION

Incident response plan development; Team training; Communication procedures; Tabletop exercises; Post-incident review process;

INCIDENT ZERO · AUDIT & COMPLIANCE

FRAMEWORK CARD

FRAMEWORK-NIST-05

RECOVER FUNCTION

FRAMEWORK: NIST CSF

FUNCTION: Recover (RC.RP - Recovery Planning, RC.IM - Improvements, RC.CO - Communications)

FOCUS: Recovering from breaches and improving for next time

ASSESSMENT CRITERIA

Recovery plan (how to restore systems); Recovery time objectives (RTO - how fast?); Recovery point objectives (RPO - how much data loss?); Backup verification (can you actually restore?); Lessons learned process (improve after incident);

SCORING (1-5 STARS)

(1): No recovery plan, no backups; (2): Backup exists, recovery not tested; (3): Recovery plan exists, tested annually; (4): Recovery plan regularly tested, RPO/RTO defined; (5): Mature recovery, tested regularly, continuous improvement;

TYPICAL FINDINGS

No recovery plan; Backups untested (may not restore); RTO/RPO not defined; Recovery team not trained; No lessons learned process;

REMEDIATION

Recovery plan development; Backup testing (quarterly); RTO/RPO definition; Recovery team training; Lessons learned process;

INCIDENT ZERO · AUDIT & COMPLIANCE

FRAMEWORK CARD

FRAMEWORK-CIS-01

SAFEGUARDS 1-6 (FOUNDATIONS)

FOCUS: Basic security practices (asset management, access control, data protection, secure configuration)

ASSESSMENT CRITERIA

Asset management (know what you have); Access control (least privilege); Data protection (encryption); Secure configuration (harden systems); Detection tools (SIEM, antivirus); Training (security awareness);

INCIDENT ZERO · AUDIT & COMPLIANCE

FRAMEWORK CARD

FRAMEWORK-CIS-02

SAFEGUARDS 7-13 (ADVANCED DEFENSES)

FOCUS: Advanced controls (incident response, supply chain, defense tools)

ASSESSMENT CRITERIA

Incident response plan; Supply chain risk; Vulnerability management; Application security; Remote services security; Testing & monitoring; Network segmentation;

INCIDENT ZERO · AUDIT & COMPLIANCE

FRAMEWORK CARD

FRAMEWORK-CIS-03

SAFEGUARDS 14-18 (OPERATIONS & GOVERNANCE)

FOCUS: Operational controls (reporting, awareness, training, testing)

ASSESSMENT CRITERIA

Security awareness training; Incident reporting; Third-party risk management; Penetration testing; Secure development practices;

INCIDENT ZERO · AUDIT & COMPLIANCE

FRAMEWORK CARD

FRAMEWORK-PCI-01

INFRASTRUCTURE SECURITY (REQUIREMENTS 1-4)

FOCUS: Network and system security for cardholder data

ASSESSMENT CRITERIA

Firewall configuration; No default credentials; Cardholder data protection; Vulnerability scanning;

INCIDENT ZERO · AUDIT & COMPLIANCE

FRAMEWORK CARD

FRAMEWORK-PCI-02

ACCESS & OPERATIONS

(REQUIREMENTS 5-10)

FOCUS: Access control and operational procedures

ASSESSMENT CRITERIA

Antivirus/malware protection; Secure system updates; Access control & authentication; Audit trails & logging;

INCIDENT ZERO · AUDIT & COMPLIANCE

FRAMEWORK CARD

FRAMEWORK-PCI-03

TESTING & COMPLIANCE

(REQUIREMENTS 11-12)

FOCUS: Testing, monitoring, and compliance management

ASSESSMENT CRITERIA

Security testing (penetration testing, vulnerability scanning); Monthly scanning; Annual penetration testing; Security policies; Training; Incident response procedures;

INCIDENT ZERO · AUDIT & COMPLIANCE

FRAMEWORK CARD

REMEDIATION-01

IMPLEMENT MFA

COST: 5 Budget

TIMELINE: 2-4 weeks

DIFFICULTY: Low-Medium

WHAT IT DOES

Deploy multi-factor authentication for all user access; Implement MFA for VPN, remote access, email, admin access; Select authentication method (authenticator app, hardware token, SMS);

PREREQUISITES

Identity management system (Domain Controller, Azure AD); User device (phone or security key); Application/system support for MFA;

IMPACT

Reduces DOMAIN-02 (Access Control) findings; Makes credential attacks (T-03, T-06) harder; Improves Incident Response and Disaster Recovery modifiers;

INCIDENT ZERO · AUDIT & COMPLIANCE

FRAMEWORK CARD

REMEDIATION-02

DEPLOY SIEM

COST: 15 Budget

TIMELINE: 4-8 weeks

DIFFICULTY: Medium

WHAT IT DOES

Deploy Security Information & Event Management (SIEM); Configure log collection from all systems; Create alert rules for suspicious activity; Implement 24/7 monitoring;

PREREQUISITES

Centralized logging infrastructure; SIEM software/service (Splunk, ELK, QRadar, Azure Sentinel); Security personnel to manage SIEM;

IMPACT

Reduces DOMAIN-03 (Threat Detection) findings; Enables early breach detection; Improves Incident Response investigation; Provides audit trail for compliance;

INCIDENT ZERO · AUDIT & COMPLIANCE

FRAMEWORK CARD

REMEDIATION-03

IMPLEMENT NETWORK SEGMENTATION

COST: 12 Budget

TIMELINE: 4-6 weeks

DIFFICULTY: Medium-High

WHAT IT DOES

Divide network into security zones (DMZ, internal, admin); Deploy firewalls between zones; Configure firewall rules for inter-zone traffic; Implement VLANs and network isolation;

PREREQUISITES

Network switches/routers capable of VLAN support; Firewall(s) for inter-zone traffic; Network diagram and access requirements;

IMPACT

Reduces DOMAIN-01 (Network Segmentation) findings; Prevents lateral movement (T-04 becomes harder); Improves Disaster Recovery (limits blast radius); Foundational for zero-trust architecture;

INCIDENT ZERO · AUDIT & COMPLIANCE

FRAMEWORK CARD

REMEDIATION-04

BACKUP & DISASTER RECOVERY

COST: 10 Budget

TIMELINE: 2-4 weeks

DIFFICULTY: Low-Medium

WHAT IT DOES

Implement 3-2-1 backup strategy (3 copies, 2 media, 1 offsite); Configure automated backups; Test backup restoration (quarterly); Document recovery procedures;

PREREQUISITES

Backup software/service; Off-site storage location; Testing schedule;

IMPACT

Reduces DOMAIN-04 (Backup & DR) findings; Enables ransomware recovery; Improves Disaster Recovery (reduces costs); Supports compliance requirements;

INCIDENT ZERO · AUDIT & COMPLIANCE

FRAMEWORK CARD

REMEDIATION-05

SECURITY TRAINING PROGRAM

COST: 3 Budget

TIMELINE: 1-2 weeks (ongoing)

DIFFICULTY: Low

WHAT IT DOES

Develop security awareness training curriculum; Conduct initial training for all employees; Implement phishing simulations; Quarterly refresher training;

PREREQUISITES

Training development (internal or vendor); Management buy-in (release time for employees);

IMPACT

Reduces DOMAIN-06 (Security Ops) findings; Reduces phishing success rate; Improves overall security culture; Compliance requirement (most frameworks);

INCIDENT ZERO · AUDIT & COMPLIANCE

FRAMEWORK CARD

REMEDIATION-06

VENDOR SECURITY ASSESSMENT

COST: 5 Budget

TIMELINE: 2-4 weeks

DIFFICULTY: Low-Medium

WHAT IT DOES

Develop vendor security questionnaire; Send questionnaires to key vendors; Review vendor security controls; Document vendor risk assessment; Establish SLAs with security requirements;

PREREQUISITES

Vendor list and criticality assessment; Security questionnaire template; Document review process;

IMPACT

Reduces DOMAIN-05 (Third-Party Risk) findings; Identifies supply chain risks; Prevents SCENARIO-03 (Supply Chain Compromise); Compliance requirement (GDPR, etc.);

INCIDENT ZERO · AUDIT & COMPLIANCE

FRAMEWORK CARD

REMEDIATION-07

VULNERABILITY MANAGEMENT PROGRAM

COST: 8 Budget

TIMELINE: 3-4 weeks

DIFFICULTY: Medium

WHAT IT DOES

Deploy vulnerability scanning tools; Establish patching procedures; Configure patch management automation; Document vulnerability remediation process;

PREREQUISITES

Vulnerability scanner (Nessus, Qualys, OpenVAS); Patch management tools or procedures; Prioritization process (critical vs. non-critical);

IMPACT

Reduces multiple audit findings; Prevents PT-05 (Privilege Escalation via unpatched kernel); Improves overall security posture;

INCIDENT ZERO · AUDIT & COMPLIANCE

INCIDENT RESPONSE PLAN & TEAM

COST: 12 Budget

TIMELINE: 4-6 weeks (plus ongoing)

DIFFICULTY: Medium-High

WHAT IT DOES

Develop incident response plan (procedures, contacts, escalation); Establish incident response team; Conduct tabletop exercises; Implement communication procedures;

PREREQUISITES

Team designation (CISO, security analysts, IT, legal, PR); Plan documentation; Training and exercises;

IMPACT

Reduces DOMAIN-03 (Threat Detection) and DOMAIN-06 (Security Ops) findings; Enables faster response to Incident Response module; Improves Disaster Recovery effectiveness; Compliance requirement (nearly universal);

